

Identity & Authentication Policy

Hewlett Packard Enterprise (HPE)

Document ID: HPE-SEC-D5 | Version 3.2 | Effective Date: 2026-07-08

Owner: Office of the Chief Information Security Officer (CISO)

Classification: Internal Use

1. Purpose and Scope

This Identity & Authentication Policy establishes the mandatory requirements governing how digital identities are provisioned, verified, and retired across Hewlett Packard Enterprise. It applies to all employees, contractors, service accounts, and third-party partners who access HPE systems, applications, and data-whether hosted on-premises, in HPE GreenLake, or in third-party cloud environments. Adherence to this policy is required to protect corporate assets, customer data, and HPE's global operations from unauthorized access and credential-based attack.

2. Identity Federation and Single Sign-On

HPE standardizes on a federated identity model built on Okta as the primary Single Sign-On (SSO) broker, integrated with Microsoft Entra ID as an authoritative identity provider for Microsoft 365 and Azure-based workloads. All new applications MUST integrate with the corporate SSO platform using modern federation protocols-SAML 2.0 or OpenID Connect (OIDC)-in preference to local authentication stores. Federation reduces password sprawl, centralizes access enforcement, and ensures that de-provisioning is immediate and comprehensive. Legacy applications that cannot support SAML or OIDC must be documented as exceptions, remediated on a defined roadmap, and protected by compensating controls. Direct LDAP or basic authentication to production systems is prohibited unless explicitly approved by the Identity Governance team.

3. Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for all interactive access to HPE resources; single-factor sign-in is never sufficient for corporate, administrative, or remote access. HPE's two-factor (2FA) posture is phishing-resistant by design:

- Primary authenticator: FIDO2 / WebAuthn security keys, delivered as company-issued YubiKeys, are the required strong authenticator for privileged, administrative, and high-risk roles. Hardware keys bind authentication to physical possession and defeat credential-replay and adversary-in-the-middle attacks.
- Biometric verification: Platform authenticators (Windows Hello for Business, Touch ID) using biometric factors are approved for workstation-bound WebAuthn flows.
- Fallback factors: Okta Verify push with number matching is permitted for standard users. SMS and voice one-time passcodes are deprecated and disallowed for any privileged context.

Step-up MFA is enforced adaptively by Okta and Entra ID Conditional Access based on device posture, network location, and risk signals.

4. Password and Passphrase Standards

Where a password or passphrase is still required-for account recovery, non-federated systems, or the primary identity store-the following standards apply:

- Length: A minimum passphrase length of 14 characters for standard accounts and 16 characters for privileged accounts. Length is prioritized over arbitrary complexity.
- Complexity: Passwords must not appear in known-breach corpora; HPE screens all new and changed passwords against a compromised-credential dictionary. Composition rules encourage passphrases over cryptic strings.
- Expiry: In alignment with NIST SP 800-63B guidance, time-based password expiry is eliminated for accounts protected by phishing-resistant MFA. Credentials are rotated on evidence of compromise rather than on a fixed calendar. Service account secrets retain a maximum 90-day rotation.
- Password reuse across corporate and personal accounts is strictly prohibited, and account lockout thresholds throttle brute-force attempts.

5. Credential, Secret, and Key Management

All non-interactive credentials-including API tokens, secrets, signing keys, and X.509 certificates-must be stored in an approved enterprise secrets vault (HashiCorp Vault or the cloud-native key management service) and never embedded in source code, configuration files, or container images. Each credential MUST have a defined owner, a documented rotation interval, and automated expiry. TLS and code-signing certificates are managed through the corporate PKI with monitored lifecycles to prevent outages and mis-issuance. Cryptographic key material is generated, stored, and retired in accordance with HPE's key management standard, using hardware security modules for root and intermediate keys. Automated scanning detects leaked secrets and tokens in repositories and pipelines, triggering immediate revocation.

6. Lifecycle, Governance, and Enforcement

Identity lifecycle events-joiner, mover, leaver-are automated through Entra ID and Okta provisioning connectors driven by the authoritative HR system. Access is granted on least-privilege and role-based principles, reviewed quarterly through access certification campaigns. Privileged accounts require just-in-time elevation and are subject to session recording. Violations of this policy may result in disciplinary action up to and including termination and, where applicable, legal referral.

7. Review

This policy is reviewed at least annually by the CISO organization and updated in response to material changes in threat landscape, technology, or regulatory obligation.